White Team Documentation
Team 11
The Grand-Master Association

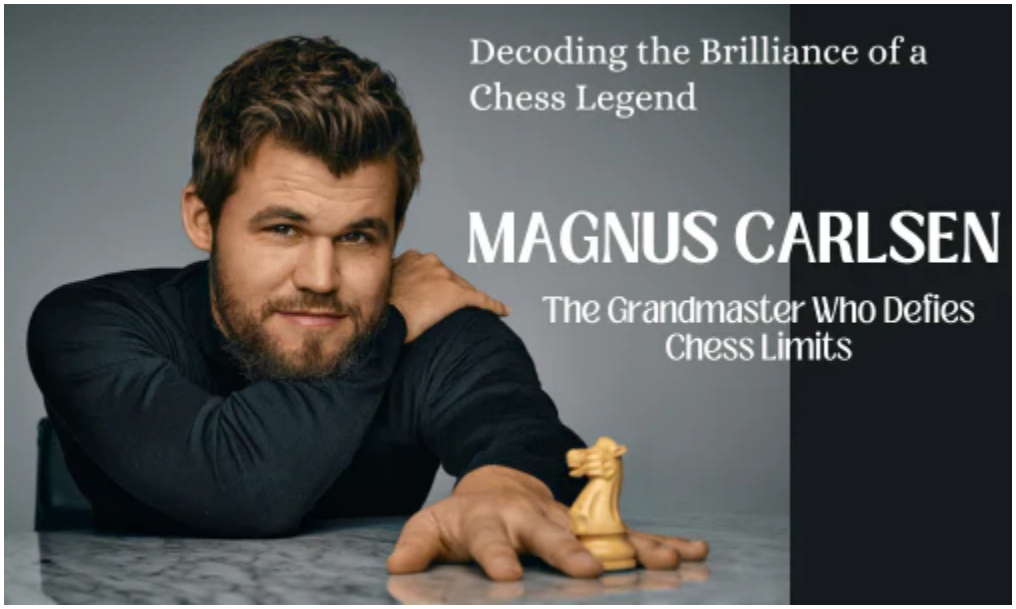


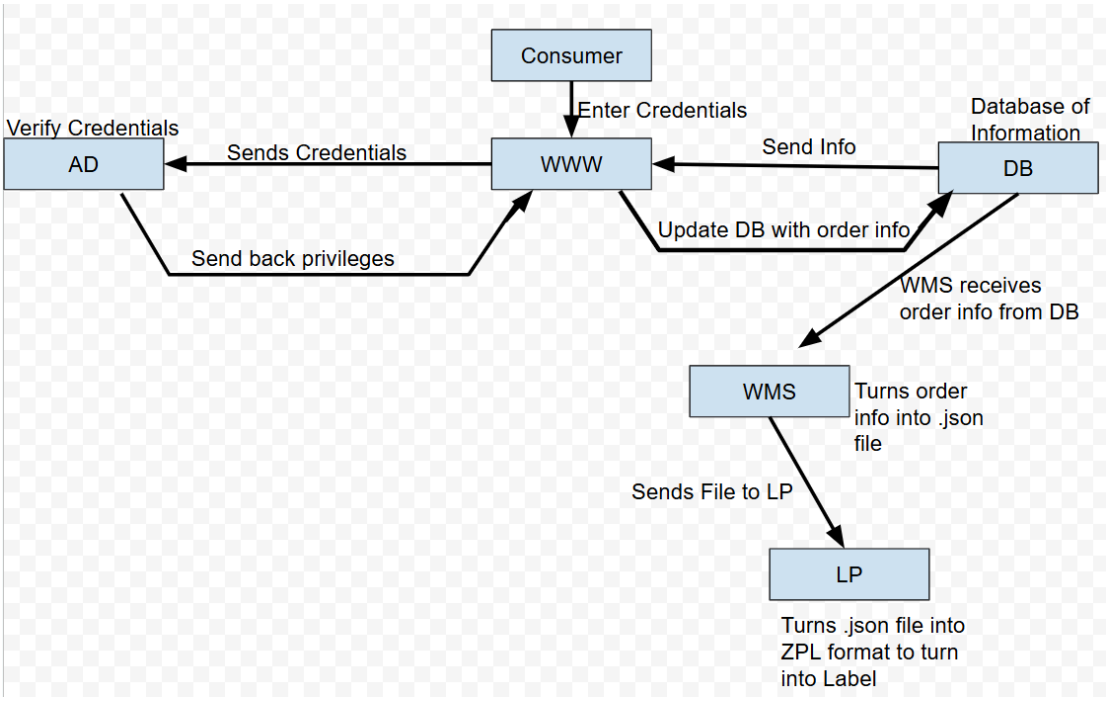
Table of Contents

Public Services
Machine Layout
IP Addresses
Firewall
AD
WWW
WMS
LP
DB

Public Services

Domain	IP	Port
www.team11.isucdc.com	76.5.61.20	80, 22

Machine Layout



IP Addresses for Machines

Machine	IP
Active Directory	76.5.61.10
WWW	76.5.61.20/24
WMS	76.5.61.40/24
Label Printer	76.5.61.30
Database	76.5.61.50/24

Firewall

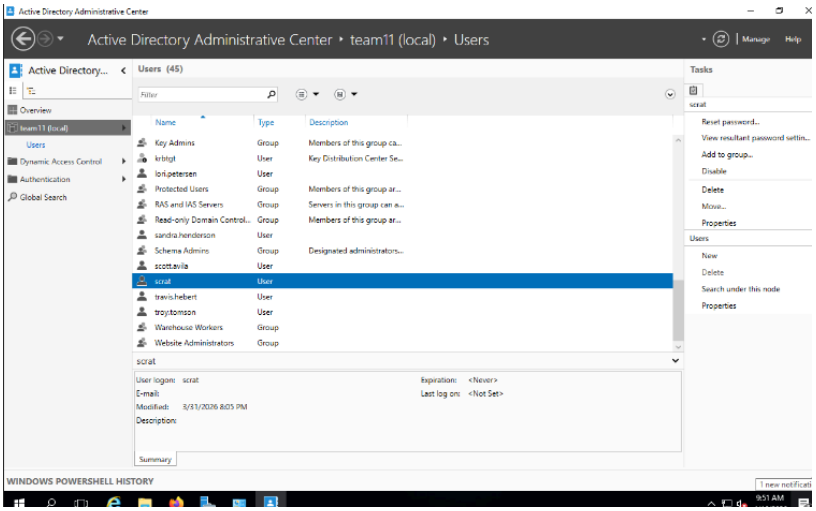
- UFW - On WWW, DB and WMS (the linux machines)
  - We downloaded, started and enabled UFW with its default settings (denying all incoming traffic and allowing all outgoing traffic)
  - Then we manually allowed some port to pass through each service (like port 80, 3306, and 22)

System	**Service**	**Allowed Incoming ports**	**Allowed Outgoing ports**	**Restricted / Blocked**
WWW	HTTP, Authorization & DB access	80 - HTTP 22 - SSH	389 - LDAP to AD 3306 - MySQL to DB	All other ports
DB	MySQL	3306 - WWW/WMS 22 - SSH	N/A	Public access to 3306 is blocked
WMS	Internal API & Processing orders	8080 - private HTTP 22 - SSH	3306 - WMS to DB 445 - SMB to LP	Public access to 8080 restricted
LP	File sharing & Printing	445 - SMB 3389 - RDP	N/A	All other ports
AD	Active Directory	389 - LDAP 3390 - RDP	Responds to authorization requests	External LDAP blocked

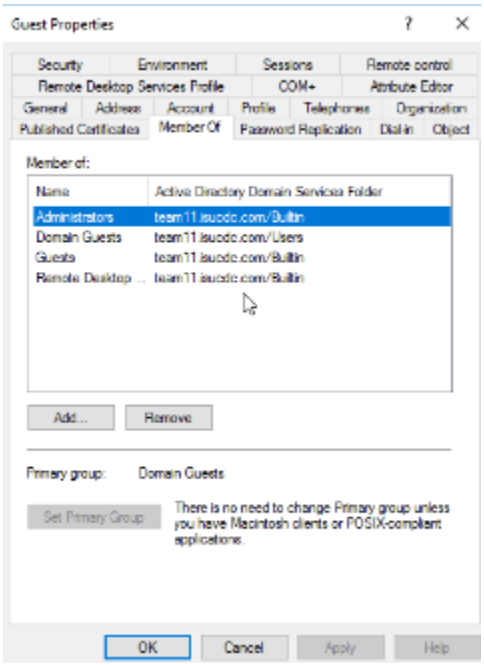
  - Doing this ensures we create a least privilege network (each system only talks to the other system that it needs too) between the services, which makes all our services more secure

Active Directory

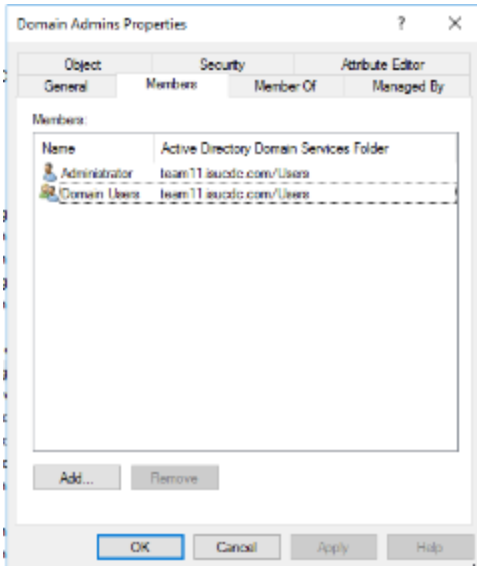
- Auditing:



  - Found users named scrat, troy.thompson, and john.leguizamo (not part of our users) in the active directory and deleted them



  - The guest user has administrative privileges and remote desktop privileges which were immediately removed

- 

    - Every domain user had domain admin privileges so we deleted domain users from the domain admin group
- Service Implementation
  - We made AD the central authentication system.
  - Everyone, including customers and admins, were made in AD and can be accessed by all services because they are all domain-joined to AD.
  - We open port 389 (LDAP) on AD, which allowed us to verify each users login through the website by sending their credentials
  - Opened port 3389 (RDP) on AD
  - AD takes the credentials from WWW and returns access and privileges
  - SMB 1 was disabled, and SMB 2 was installed

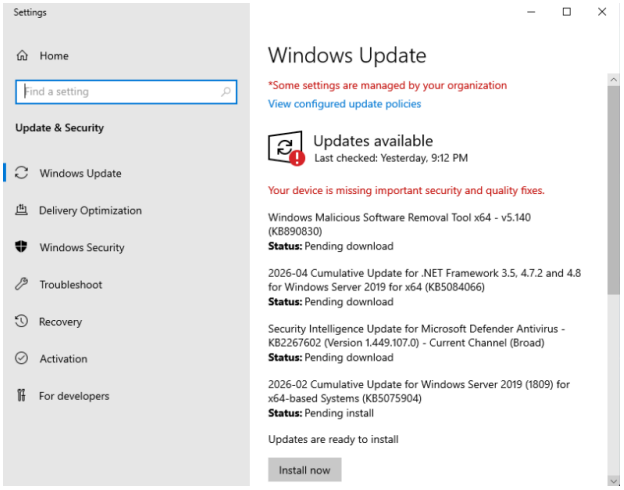
WWW

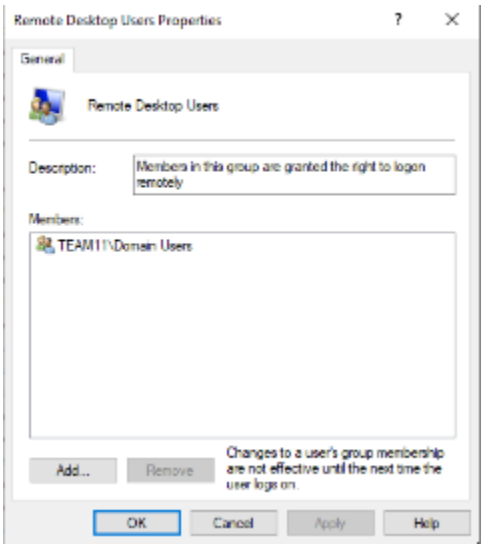
- Auditing:
  - ```
    # Allow Domain Users to use sudo
    %Domain\ Users ALL=(ALL) ALL
    ```
    - Found this under sudo visudo and deleted it to prevent all users from being root
- Service Implementation
  - We opened port 80 (for HTTP) on the WWW machine
  - We opened port 22 (for SSH) on the WWW Machine
  - We debugged some issues with the web server so it would properly send the login requests to AD and get information from the DB.
  - Making sure the request going to AD and the information coming from DB is correct allowed us to ensure the users don't face any trouble logging in.
  - We corrected DNS resolution so that the domain pointed to the correct IP
  - To connect WWW to DB, we set up a MySQL database on DB so that the WWW can safely read and write to the data
  - To ensure that real-time data (like prices, stocks and orders) is being passed around, we opened port 3306. Opening port 3306 allowed communication between WWW, WMS, and DB
  - We also corrected some credential inconsistencies and blocked ports not being used to ensure smooth communication and more safety.

WMS

- Auditing:
  - ```
    # Allow Domain Users to use sudo
    %Domain\ Users ALL=(ALL) ALL
    ```
    - Found this under sudo visudo that gave sudo to all domain users and deleted immediately.
- Service Implementation
  - It is constantly asking DB for new orders (through port 3306). When it gets a new order, it converts the data to a .json file
  - To ensure this process goes smoothly
    - We ran a backend service on WMS
    - Open port 8080 (which is a private HTTP service, so only admins can access it)
    - Debugged the service that handled the order parsing and the process that makes the files
  - Then, it sends the .json file it creates to LP on port 445
  - We opened port 22 (for SSH) on the WMS Machine

Label Printer

- Auditing:
  - 

    - Updated the windows machine
  - 

    - Under the remote desktop users group the members were every domain user. Only IT Admins need to RDP into LP so domain users were deleted and IT admins were added.
- Service Implementation
  - LP gets the .json file and turns it into shipping labels, to do this, we had to ensure the file transferring and printing services ran correctly and together
  - We opened SMB (port 445) which receives the .json file from WMS
  - Opened port 3389 (RDP) on LP
  - To store the incoming files, we set up a shared folder on LP

- We modified the permissions so WMS has write access to that storage folder. This allows WMS to directly place the files on the LP system for it to use.
- When the .json file enters the folder, LP machine's software that monitors the folders constantly detects it and reads all the details (name, address, etc)
- The read data is converted into a ZPL file which is the format the is needed to use the LP, it interprets the ZPL and prints the shipping label
- LP is domain joined with AD, so admins can use their centralized credentials to access everything on the machine and make changes. Remote access is enabled via RDP (port 3389)

Database

- Auditing:
  - ```
    richard:x:1000:1000:richard,,,:/home/richard:/bin/bash
    mysql:x:110:117:MySQL Server,,,:/nonexistent:/bin/false
    cdc:x:1001:1001:Administrator,,,:/home/cdc:/bin/bash
    sshd:x:111:65534::/var/run/sshd:/usr/sbin/nologin
    scrat:x:1002:1002:,,,:/home/scrat:/bin/bash
    manny:x:1003:1003:,,,:/home/manny:/bin/bash
    sssd:x:112:118:SSSD system user,,,:/var/lib/sss:/bin/false
    ```
    - Found 2 malicious users, scrat and manny and deleted both of them
  - ```
    # Allow Domain Users to use sudo
    %Domain\ Users ALL=(ALL) ALL
    ```
    - In the /etc/sudoers.tmp file, this line was found and deleted
  - ```
    cdc@db:/etc$ sudo deluser --remove-all-files richard
    ```
    - Realized Richard was not supposed to be a linux user on DB, only a mysql user so we deleted him as well
  - ```
    cdc@db:/etc$ sudo deluser --remove-all-files richard
    ```
- Service Implementation
  - We installed and modified MySQL on the DB, then we used it to create tables with users, products, orders, etc.
  - We defined relationships between these tables (like orders are linked to users and orders) so we can actually use them efficiently
  - We opened port 22 (for SSH) on the DB Machine and port 3306 (MySQL) to communicate with and transfer information to WWW and WMS. We also changed some firewall rules to allow communication with only WWW and WMS
    - WWW is giving order information and getting credential information

        - WMS is getting information from DB which is used by LP
    - We fixed connection time out errors between the service and updated the data correctly after orders. We also tried to make this the safest machine possible because it holds all the information